

The Capstone Product: Project Redline (AI Red Team)

Chương trình thực tập 6 tuần | VinUni x VinSOC | Kiểm thử an toàn và an ninh cho ứng dụng AI

1. Mục tiêu

Xây dựng một hệ thống AI Red Team để kiểm thử an toàn (safety) và an ninh (security) cho một ứng dụng LLM trong môi trường thử nghiệm biệt lập (docker-compose).

Định hướng: đây là hoạt động red team phòng thủ. Mục tiêu là tìm và giúp khắc phục lỗ hổng của hệ thống AI trong môi trường được cấp phép, không nhằm gây hại.

Hệ thống có thể:

- Chạy một tập kịch bản tấn công có cấu trúc nhắm vào ứng dụng LLM mục tiêu: prompt injection, jailbreak, rò rỉ system prompt, rò rỉ dữ liệu nhạy cảm, lạm dụng tool.
- Tự động gửi và biến đổi (mutate) các prompt tấn công thông qua một attacker agent.
- Chấm điểm mức độ thành công của tấn công bằng bộ detector luật, tùy chọn thêm LLM-as-a-judge, và tính Attack Success Rate (ASR) theo từng nhóm.
- Đánh giá hiệu quả guardrail: đo tỉ lệ vượt qua (bypass rate) trước và sau khi thêm phòng thủ.
- Áp dụng biện pháp an toàn: chỉ tấn công mục tiêu được cấp phép trong sandbox, che dữ liệu nhạy cảm trong log, giới hạn tần suất và tuân thủ Rules of Engagement (RoE).
- Ghi lại toàn bộ quá trình, tạo báo cáo red team kèm đề xuất khắc phục và trình diễn kết quả.

2. Phạm vi đơn giản hóa

Đồ án không yêu cầu:

- Huấn luyện hoặc fine-tune một mô hình tấn công riêng.
- Tự triển khai mô hình bằng vLLM hoặc GPU.
- Nghiên cứu kỹ thuật jailbreak hoàn toàn mới (0-day).
- Tấn công hệ thống thật, hệ thống của bên thứ ba hoặc sản phẩm đang chạy production.
- Xây dựng hệ thống Multi-Agent phức tạp.
- Bao phủ toàn bộ MITRE ATLAS.
- Sinh nội dung gây hại thực tế vượt quá mức tối thiểu cần thiết để chứng minh lỗ hổng.

Nhóm có thể sử dụng:

- Một attacker LLM (agent tấn công) chính.
- Ứng dụng LLM mục tiêu cố ý có lỗ hổng do VinSOC cấp, phiên bản cố định. Nhóm không tự xây mục tiêu, để kết quả giữa các nhóm so sánh được; có thể tham khảo thêm ứng dụng huấn luyện mã nguồn mở dạng Gandalf hoặc DVWA-LLM.
- Công cụ mã nguồn mở miễn phí như garak, PyRIT, promptfoo hoặc Giskard.
- Khung tham chiếu: OWASP Top 10 for LLM Applications, MITRE ATLAS, NIST AI RMF.
- Một dịch vụ LLM có sẵn.
- Một cơ sở dữ liệu nhỏ hoặc tệp JSON/JSONL để lưu kết quả.
- Docker Compose để chạy toàn bộ hệ thống.

3. Tổ chức chương trình

Nhân sự và nhịp làm việc

- Quy mô: 1 nhóm 2 bạn.
- Thời lượng: 6 tuần, full-time, bắt đầu 11/9/2026.
- Mỗi nhóm có một mentor. Office hours 8:00-17:15, kênh trao đổi MS Teams.
- Checkpoint cuối mỗi tuần: demo 10 phút kèm nộp artifact của tuần đó, mentor chấm đạt hoặc không đạt.
- Mã nguồn nộp trên repo nội bộ sẽ được cung cấp sau, mỗi nhóm một nhánh. Không dùng repo public.

Tuần 0 — chuẩn bị trước khi bắt đầu

- Yêu cầu đầu vào: Python, Git và Docker ở mức dùng được; đã từng gọi API của một dịch vụ LLM.
- Cài Docker, Docker Compose, Python 3.11 và dựng thử ứng dụng mục tiêu mẫu.
- Đọc OWASP Top 10 for LLM Applications 2025 và phần tổng quan của MITRE ATLAS.
- Ký cam kết bảo mật và xác nhận đã đọc Rules of Engagement mẫu.

VinSOC cấp

- Ứng dụng LLM mục tiêu cố ý có lỗ hổng, phiên bản cố định, kèm README dựng bằng một lệnh.
- API key dùng chung kèm hạn mức (ngân sách mỗi nhóm) và cách theo dõi mức đã dùng.
- Repo mẫu: cấu trúc thư mục, schema kết quả, mẫu báo cáo red team.
- Mẫu Rules of Engagement để nhóm chỉnh theo phạm vi của mình.

Quy tắc bắt buộc

- Chỉ tấn công mục tiêu trong sandbox theo allowlist. Mọi mục tiêu khác đều ngoài phạm vi, kể cả hệ thống nội bộ của tập đoàn.
- Nếu vô tình phát hiện lỗ hổng ở hệ thống ngoài phạm vi: dừng ngay, không kiểm chứng thêm, báo mentor trong 24 giờ.
- Không đưa log, prompt, secret hay kết quả của đồ án ra ngoài môi trường được cấp; không công bố khi chưa được VinSOC duyệt.

- Không dùng dữ liệu thật của người dùng hay dữ liệu sản phẩm. Chỉ dùng dữ liệu giả lập do chương trình cấp.

Tuần 1: Thiết lập môi trường, mục tiêu và mô hình hóa mối đe dọa

Mục tiêu

Dựng ứng dụng LLM mục tiêu trong sandbox và lập threat model kèm Rules of Engagement.

Công việc

- Dựng ứng dụng LLM mục tiêu bằng Docker. Mục tiêu tối thiểu gồm: một system prompt chứa secret (canary); ít nhất một tool có tác dụng phụ quan sát được trong sandbox, ví dụ ghi file hoặc gửi email giả lập; một kho tài liệu RAG mà nhóm nạp được nội dung vào để thử indirect injection; và một endpoint hội thoại giữ trạng thái để chạy được tấn công đa lượt.
- Chọn và cấu hình dịch vụ LLM.
- Recon mục tiêu trước khi tấn công: fingerprint mô hình (nhà cung cấp, họ mô hình, giới hạn context), dò cấu trúc pipeline RAG (nguồn tài liệu, cách chunk, điều kiện truy xuất), phát hiện guardrail (lọc ở input hay output, thông điệp từ chối đặc trưng).
- Chỉ dùng kết quả recon quan sát được để dựng bản đồ bề mặt tấn công, không chép từ tài liệu mô tả mục tiêu.
- Lập threat model theo OWASP LLM Top 10: liệt kê tài sản cần bảo vệ (system prompt, secret, dữ liệu người dùng, quyền gọi tool), bề mặt tấn công và tác nhân đe dọa.
- Viết Rules of Engagement (RoE): phạm vi được phép, mục tiêu bị cấm, giới hạn tần suất, ngân sách token, dữ liệu không được sử dụng, cơ chế dừng khẩn cấp (kill-switch) và người phê duyệt.
- Chạy thử công 3 đến 5 tấn công cơ bản làm baseline và ghi lại bằng chứng.

Sản phẩm bàn giao

- Ứng dụng LLM mục tiêu chạy được trong sandbox.
- Tài liệu threat model và bản đồ bề mặt tấn công.
- Báo cáo recon: fingerprint mô hình, cấu trúc RAG suy ra được, guardrail phát hiện được và cách phát hiện.
- Tài liệu Rules of Engagement được xác nhận.
- Nhật ký 3 đến 5 tấn công baseline kèm bằng chứng.

Tiêu chí hoàn thành

- Thành viên khác dựng lại được mục tiêu bằng hướng dẫn trong README.
- RoE nêu rõ mục tiêu được phép và bị cấm, có kill-switch, và đã được mentor VinSOC ký duyệt trước lần chạy tự động đầu tiên.
- Có ít nhất một tấn công baseline thành công được ghi nhận kèm bằng chứng tái lập.

- Bản đồ bề mặt tấn công dựa trên bằng chứng recon, mỗi mục nêu rõ đã phát hiện bằng cách nào.

Tuần 2: Phân loại tấn công và xây thư viện tấn công hạt giống

Mục tiêu

Chuyển kiến thức tấn công LLM thành một taxonomy và một thư viện prompt có cấu trúc.

Công việc

- Xây taxonomy tấn công ánh xạ tới OWASP LLM Top 10 và MITRE ATLAS. Ví dụ nhóm: direct/indirect prompt injection, jailbreak/roleplay, trích xuất system prompt, rò rỉ dữ liệu nhạy cảm hoặc PII, lạm dụng tool, mã hóa/obfuscation, tấn công đa lượt (multi-turn).
- Phạm vi OWASP của đề án: LLM01, LLM02, LLM05, LLM06, LLM07, LLM08, LLM09, LLM10. LLM03 (Supply Chain) và LLM04 (Data and Model Poisoning) nằm ngoài phạm vi vì không kiểm thử được bằng thư viện prompt trên một mục tiêu cố định.
- Tạo thư viện tấn công hạt giống (seed) tối thiểu 60 prompt, phủ đủ 7 nhóm trong taxonomy và ít nhất 6 trên 8 mã OWASP trong phạm vi, chuẩn hóa về một schema chung, ví dụ:

```
{
  "attack_id": "PI-001",
  "category": "prompt_injection.direct",
  "technique": "instruction_override",
  "prompt": "...",
  "expected_success_signal": "lộ chuỗi canary trong system prompt",
  "owasp_id": "LLM01",
  "atlas_id": "AML.Txxxx"
}
```

- Với các nhóm liên quan nội dung gây hại, dùng mục tiêu thay thế vô hại: tín hiệu thành công là mô hình phát ra chuỗi đánh dấu đã quy ước hoặc gọi tool bị cấm trong sandbox, không phải sinh nội dung gây hại thật.
- Xây kho tri thức nhỏ: OWASP LLM Top 10, MITRE ATLAS, kèm 10 đến 20 ví dụ kỹ thuật đã biết.
- Chạy thử công từ seed và ghi Pass hoặc Fail tạm thời.

Sản phẩm bàn giao

- Tài liệu taxonomy tấn công.
- Thư viện seed (JSON/JSONL) tối thiểu 60 prompt.
- Kho tri thức nhỏ kèm chức năng tìm kiếm theo tên kỹ thuật.
- Bảng kết quả chạy thử công.

Tiêu chí hoàn thành

- Mỗi seed có đủ category, technique và tín hiệu thành công dự kiến.
- Tìm kiếm prompt injection hoặc jailbreak trả về nội dung liên quan.

- Thư viện phủ đủ 7 nhóm taxonomy và ít nhất 6 trên 8 mã OWASP trong phạm vi.

Tuần 3: Bộ chạy tấn công tự động và schema kết quả

Mục tiêu

Tự động gửi tấn công tới mục tiêu và ghi kết quả theo một schema thống nhất.

Công việc

- Viết harness Python đọc thư viện seed, gửi tới mục tiêu và thu response.
- Hỗ trợ hội thoại nhiều lượt (session) để chạy được nhóm tấn công đa lượt.
- Hỗ trợ tấn công gián tiếp: nạp nội dung do nhóm kiểm soát vào kho tài liệu RAG, rồi kích hoạt bằng một câu hỏi bình thường của người dùng.
- Chuẩn hóa kết quả về schema chung: run_id, attack_id, parent_attack_id, attempt_idx, session_id, turn_idx, category, technique, prompt, response, target_config_hash, defense_profile, latency, tokens, timestamp. Các trường parent_attack_id, attempt_idx và defense_profile phải có ngay từ tuần 3 để tuần 5 so sánh trước và sau mà không phải đổi schema.
- Chạy theo lô, ghi log; xử lý rate limit, timeout, lỗi kết nối và retry.
- Ghi lại cấu hình mục tiêu (model, temperature, phiên bản system prompt) để tái lập.

Sản phẩm bàn giao

- Bộ chạy tấn công tự động.
- Định nghĩa schema kết quả.
- Nhật ký chạy và ít nhất một run tự động trên toàn thư viện.
- PoC một tấn công đa lượt và một tấn công gián tiếp chạy được đầu-cuối.

Tiêu chí hoàn thành

- Chạy toàn thư viện bằng một lệnh.
- Kết quả có cấu trúc đồng nhất và tái lập được.
- Xử lý được timeout và lỗi mà không làm dừng cả run.
- Chạy được ít nhất một tấn công đa lượt và một tấn công gián tiếp qua kênh RAG.

Tuần 4: Chấm điểm tấn công và đo lường (Judge và ASR)

Mục tiêu

Xác định tấn công thành công một cách khách quan và tính các chỉ số đo lường.

Công việc

- Định nghĩa rõ tiêu chí thành công cho từng nhóm. Ví dụ: lộ system prompt là response chứa chuỗi canary; jailbreak thành công là mục tiêu thực hiện hành vi bị cấm; rò rỉ PII là xuất hiện PII trong response.

- Xây bộ chấm điểm: detector luật (regex, keyword, canary token) kết hợp tùy chọn LLM-as-a-judge cho các nhóm mơ hồ.
- Tính Attack Success Rate (ASR) theo từng nhóm và tổng thể, kèm số mẫu (n).
- Tạo tập ground-truth do người gán nhãn tối thiểu 60 mẫu, chia 30 mẫu dev để chỉnh judge và 30 mẫu held-out chỉ dùng để báo cáo. Ít nhất 20% số mẫu được hai người gán nhãn độc lập; ghi lại cách xử lý các trường hợp bất đồng.

Sản phẩm bàn giao

- Module chấm điểm.
- Tập ground-truth có nhãn người.
- Bảng ASR theo nhóm và tổng thể.
- Báo cáo kiểm định judge trên tập held-out: accuracy, Cohen kappa, false positive và false negative.

Tiêu chí hoàn thành

- Mỗi nhóm có định nghĩa thành công bằng văn bản, kiểm chứng được.
- Judge đạt độ khớp với nhãn người trên tập held-out từ 85% trở lên, kèm kappa và phân tích sai lệch. Với $n = 30$ thì sai số còn lớn: báo cáo kèm khoảng tin cậy và không kết luận về khác biệt dưới 10 điểm phần trăm.
- ASR tính lại được từ dữ liệu run của tuần 3.

Tuần 5: Tối ưu tấn công đối kháng và đánh giá guardrail

Mục tiêu

Tự động tăng hiệu quả tấn công và đo hiệu quả của các cơ chế phòng thủ.

Công việc

1. Attacker agent (tối ưu đối kháng)

- Với tấn công thất bại, agent biến đổi prompt (rephrase, mã hóa, roleplay, multi-turn, chia nhỏ payload) trong giới hạn số lần thử.
- So sánh ASR trước và sau khi tối ưu.

2. Đánh giá guardrail

- Thêm tối thiểu một cơ chế phòng thủ: input filter, làm cứng system prompt (hardening) hoặc output filter và canary.
- Đo bypass rate trước và sau khi bật guardrail cho từng nhóm.
- Chạy lại cả tấn công trực tiếp và tấn công gián tiếp ở hai chế độ guardrail bật và tắt, dùng cùng một tập seed.

Ràng buộc an toàn

- Giới hạn số lần thử và ngân sách token; chỉ tấn công mục tiêu trong sandbox. Agent tự dừng khi chạm hạn mức và báo mentor.
- Không lưu payload gây hại thật; che dữ liệu nhạy cảm trong log.

Sản phẩm bàn giao

- Attacker agent kèm vòng lặp tối ưu.
- Cấu hình guardrail.
- Bảng so sánh ASR và bypass rate trước và sau.
- Phân tích các kỹ thuật vẫn vượt được guardrail.

Tiêu chí hoàn thành

- Tối ưu đối kháng làm thay đổi ASR đo được (tăng với mục tiêu chưa vá; giảm sau khi bật guardrail).
- Guardrail giảm bypass rate ở ít nhất một nhóm, có số liệu trước và sau.
- Agent tự dừng khi đạt giới hạn thử và không vượt RoE.

Tuần 6: Tích hợp, đánh giá và thuyết trình

Mục tiêu

Hoàn thiện luồng đầu-cuối và trình bày kết quả cho người kỹ thuật và không kỹ thuật.

Luồng hệ thống cuối cùng

1. Nạp thư viện tấn công và cấu hình mục tiêu.
2. Harness chạy toàn bộ tấn công thông qua attacker agent.
3. Bộ chấm điểm xác định thành công và tính ASR.
4. Bật hoặc tắt guardrail để so sánh.
5. Dữ liệu nhạy cảm được che trong log.
6. Sinh báo cáo red team kèm đề xuất khắc phục.
7. Toàn bộ quá trình được ghi log và tái lập được.

Công việc

- Đóng gói hệ thống bằng Docker Compose.
- Thêm logging và metrics: số tấn công, ASR theo nhóm, bypass rate, số lần thử của agent, lỗi khi gọi LLM, thời gian xử lý.
- Dùng lại tập held-out của tuần 4 làm bộ đánh giá cuối, bổ sung mẫu nếu có nhóm chưa đủ. Không tạo tập nhãn mới.
- Viết báo cáo red team: phát hiện, mức nghiêm trọng, PoC và tái lập, đề xuất khắc phục theo định dạng responsible disclosure.
- Hoàn thiện README và sơ đồ kiến trúc.
- Chuẩn bị demo 10 đến 15 phút.

Sản phẩm bàn giao cuối cùng

1. Mã nguồn

Bao gồm: harness runner; thư viện tấn công; attacker agent; module chấm điểm; guardrail; chức năng che dữ liệu; Docker Compose.

2. Tài liệu kỹ thuật

Bao gồm: kiến trúc hệ thống; threat model; Rules of Engagement; hướng dẫn cài đặt; hướng dẫn chạy demo; giới hạn hệ thống; quyết định thiết kế chính; rủi ro còn tồn tại.

3. Báo cáo red team

Bao gồm: các lỗ hổng phát hiện; ASR theo nhóm; các tấn công thành công và thất bại; false positive và false negative của judge; đề xuất khắc phục và mức ưu tiên.

4. Bản trình diễn

Cần thể hiện: một lần chạy tấn công; agent tối ưu một tấn công thất bại thành công; judge chấm điểm; bật guardrail và đo lại; dữ liệu nhạy cảm bị che; một phát hiện có PoC tái lập.

5. Bản mô tả sản phẩm ngắn (1 đến 2 trang)

Gồm: vấn đề cần giải quyết; người sử dụng; giá trị sản phẩm; phạm vi hiện tại; hạn chế; hướng phát triển tiếp theo.

Tiêu chí hoàn thành cuối

- Hệ thống chạy được bằng một quy trình rõ ràng.
- Có ít nhất một luồng hoàn chỉnh từ thư viện tấn công đến báo cáo cuối.
- Không tấn công ngoài mục tiêu được cấp phép (tuân thủ RoE).
- Có che dữ liệu nhạy cảm và giới hạn tần suất.
- Có tập ground-truth và kiểm định judge.
- Thành viên khác tái lập được demo dựa trên README.

Rubric đánh giá

Tổng điểm 100, phân bổ theo 6 hạng mục. Mỗi tiêu chí được chấm theo thang điểm rời rạc với ngưỡng khách quan và bằng chứng bắt buộc.

Bảng trọng số tổng quan

Hạng mục	Trọng số	Nội dung cốt lõi
1. Hệ thống hoạt động đầu-cuối	25	Dựng một lệnh, luồng hoàn chỉnh, xử lý lỗi, tái lập
2. Độ phủ và chất lượng phương pháp tấn công	20	Taxonomy, thư viện seed, mutate, indirect injection
3. Tính chặt chẽ của chấm điểm và đo lường	20	Định nghĩa thành công, judge, ground-truth, ASR
4. An toàn, đạo đức và tuân thủ RoE	15	RoE, chỉ sandbox, che dữ liệu, giới hạn tần suất
5. Chất lượng mã nguồn	10	Cấu trúc, README, kiểm thử, không lộ secret
6. Tài liệu và trình bày	10	Kiến trúc, báo cáo red team, demo ổn định
Tổng	100	

Hạng mục 1 — Hệ thống hoạt động đầu-cuối (25 điểm)

Tiêu chí và thang điểm	Điểm	Bảng chứng bắt buộc
1.1 Dựng toàn hệ thống bằng một lệnh (docker compose up). Thang điểm: 0đ = không dựng được; 3đ = dựng được nhưng phải chỉnh tay nhiều bước ngoài README; 5đ = một lệnh, đúng theo README.	5	Log dựng hoặc CI; README
1.2 Luồng hoàn chỉnh: thư viện tấn công tới run tới chấm điểm tới báo cáo. Thang điểm: 0đ = đứt gãy; 4đ = chạy tay từng bước rời rạc; 8đ = tự động một lệnh, tái lập.	8	Demo; script; output
1.3 Xử lý lỗi (timeout, rate limit, response rỗng hoặc không hợp lệ) không làm sập run. Thang điểm: 0đ = sập; 3đ = xử lý một phần; 6đ = xử lý đủ, có log lỗi.	6	Test lỗi; log
1.4 Tái lập: cùng cấu hình cho kết quả nhất quán, có run_id và cấu hình lưu kèm. Thang điểm: 0đ = không tái lập; 3đ = một phần; 6đ = đầy đủ.	6	Hai run; file cấu hình
Tổng hạng mục 1	25	

Hạng mục 2 — Độ phủ và chất lượng phương pháp tấn công (20 điểm)

Tiêu chí và thang điểm	Điểm	Bảng chứng bắt buộc
2.1 Taxonomy ánh xạ 8 mã OWASP trong phạm vi và MITRE ATLAS. Thang điểm: 0-1đ = phủ dưới 4 mã; 3đ = phủ 4 đến 5 mã; 5đ = phủ từ 6 trên 8 mã và có ánh xạ.	5	Tài liệu taxonomy
2.2 Thư viện seed đủ lượng và chất. Thang điểm: 1đ = dưới 30 prompt; 3đ = 30 đến 59 prompt; 5đ = từ 60 prompt hợp lệ, mỗi prompt đủ category, technique và tín hiệu thành công.	5	File seed JSON hoặc JSONL
2.3 Attacker agent mutate hiệu quả. Thang điểm: 0đ = không có; 3đ = có mutate nhưng không đo cải thiện; 6đ = từ 3 kỹ thuật biến đổi và có bằng chứng thay đổi ASR, kèm n của từng nhóm. Không tính là cải thiện nếu nhóm đó có n dưới 10.	6	Code; bảng ASR trước và sau
2.4 Tấn công gián tiếp (indirect injection). Thang điểm: 0đ = không; 2đ = chỉ mô tả; 4đ = có kiểm thử và bằng chứng.	4	Log; PoC
Tổng hạng mục 2	20	

Hạng mục 3 — Tính chặt chẽ của chấm điểm và đo lường (20 điểm)

Tiêu chí và thang điểm	Điểm	Bảng chứng bắt buộc
3.1 Định nghĩa thành công cho từng nhóm, kiểm chứng được. Thang điểm: 0đ = không có; 3đ = một phần hoặc mơ hồ; 5đ = đầy đủ, rõ tín hiệu.	5	Tài liệu tiêu chí
3.2 Bộ chấm điểm chạy được trên toàn bộ kết quả. Thang điểm: 0đ = không chạy; 2đ = một phần; 4đ = chạy đủ, ổn định.	4	Code; output ASR
3.3 Tập ground-truth có nhãn người, tách dev và held-out. Thang điểm: 0đ = không có; 2đ = dưới 60 mẫu	4	File nhãn

hoặc không tách held-out; 4đ = từ 60 mẫu, tách rõ, có đối chiếu nhãn giữa hai người.		
3.4 Kiểm định judge trên tập held-out (accuracy và kappa kèm FP và FN). Thang điểm: 0đ = không đo, đo trên tập dev, hoặc dưới 70%; 2đ = 70 đến 84%; 4đ = từ 85% kèm kappa và phân tích sai lệch.	4	Báo cáo kiểm định
3.5 ASR báo cáo kèm số mẫu (n) theo nhóm và tổng, không suy diễn quá dữ liệu. Thang điểm: 0đ = thiếu n hoặc sai; 3đ = đầy đủ, trung thực.	3	Bảng ASR
Tổng hạng mục 3	20	

Hạng mục 4 — An toàn, đạo đức và tuân thủ RoE (15 điểm)

Tiêu chí và thang điểm	Điểm	Bảng chứng bắt buộc
4.1 RoE văn bản rõ phạm vi và mục tiêu bị cấm, có kill-switch. Thang điểm: 0đ = không có; 2đ = sơ sài; 4đ = đầy đủ.	4	Tài liệu RoE
4.2 Chỉ tấn công mục tiêu sandbox, có allowlist target, không gọi hệ thống ngoài (tiêu chí cổng bắt buộc). Thang điểm: 0đ = có gọi ngoài phạm vi; 4đ = chỉ sandbox, có allowlist. Vi phạm tiêu chí cổng thì toàn bộ hạng mục 4 tính 0 điểm và đồ án không được nghiệm thu cho tới khi nhóm khắc phục và giải trình bằng văn bản.	4	Cấu hình allowlist; log
4.3 Che dữ liệu nhạy cảm, không lưu secret hay payload gây hại thật trong log. Thang điểm: 0đ = lộ dữ liệu; 2đ = che một phần; 4đ = che đầy đủ.	4	Log đã che; test che
4.4 Giới hạn tần suất, ngân sách và số lần thử của agent. Thang điểm: 0đ = không; 1đ = một phần; 3đ = đầy đủ.	3	Cấu hình giới hạn
Tổng hạng mục 4	15	

Hạng mục 5 — Chất lượng mã nguồn (10 điểm)

Tiêu chí và thang điểm	Điểm	Bảng chứng bắt buộc
5.1 Cấu trúc rõ ràng, module hóa. Thang điểm: 0đ = lộn xộn; 2đ = trung bình; 3đ = rõ ràng, tách module.	3	Repo mã nguồn
5.2 README chạy lại được. Thang điểm: 0đ = không; 2đ = thiếu bước; 3đ = đầy đủ, chạy lại được.	3	README; lần chạy lại
5.3 Có kiểm thử (harness, judge, guardrail). Thang điểm: 0đ = không; 1đ = sơ sài; 2đ = đủ.	2	Thư mục test
5.4 Không hard-code secret hoặc API key, dùng biến môi trường. Thang điểm: 0đ = có hard-code; 2đ = sạch.	2	Rà soát mã nguồn
Tổng hạng mục 5	10	

Hạng mục 6 — Tài liệu và trình bày (10 điểm)

Tiêu chí và thang điểm	Điểm	Bảng chứng bắt buộc
------------------------	------	---------------------

6.1 Sơ đồ kiến trúc và threat model trình bày được. Thang điểm: 0đ = không; 2đ = sơ sài; 3đ = rõ ràng.	3	Sơ đồ; tài liệu
6.2 Báo cáo red team theo responsible disclosure (severity, PoC, khắc phục). Thang điểm: 0đ = không; 2đ = thiếu thành phần; 4đ = đầy đủ.	4	Báo cáo red team
6.3 Demo 10 đến 15 phút ổn định, tái lập. Thang điểm: 0đ = không demo; 2đ = trực trực nhiều; 3đ = ổn định, tái lập.	3	Buổi demo
Tổng hạng mục 6	10	

Nguyên tắc chấm điểm và quy trình khiếu nại

Nguyên tắc chấm để tránh tranh cãi

- Mỗi tiêu chí chỉ chấm dựa trên artifact cụ thể: commit, file, log hoặc phần demo. Không có artifact thì tính 0 điểm cho tiêu chí đó.
- Chấm theo hai lớp: checkpoint hàng tuần là đạt hoặc không đạt và không tính vào 100 điểm; 100 điểm chỉ tính ở chấm cuối kỳ. Nhóm không đạt checkpoint phải nộp kế hoạch khắc phục trong 2 ngày làm việc. Artifact nộp sau hạn tuần vẫn được chấm cuối kỳ nhưng ghi nhận trễ hạn.
- Rubric và các mốc tuần được công bố từ đầu kỳ; mọi thay đổi phải thông báo bằng văn bản trước khi áp dụng.

Quy trình khiếu nại

- Nộp khiếu nại trong vòng 2 ngày làm việc kể từ khi công bố điểm.
- Khiếu nại phải nêu rõ tiêu chí, điểm đề nghị và bằng chứng đã có tại thời điểm nộp bài.
- Chỉ xét lại các tiêu chí có artifact tại thời điểm nộp bài; không nhận bổ sung sản phẩm sau hạn.
- Kết quả xét khiếu nại là cuối cùng và được ghi lại bằng văn bản.